DAY 08 | PRE-READ

Keys, Guards and Helpers

A light read before Day 8. About 15 minutes, no code required.

Prepared by **Ahmed** | linkedin.com/in/ahmed-al-imaad

Why read this?

So far, anyone could call your API and do anything. Tomorrow you will add the things every real application needs: shared helpers, a checkpoint around every request, and a secure way to prove who someone is.

1. Asking for what you need

In a hospital, a surgeon does not fetch instruments; they ask and a nurse hands them over. The surgeon focuses on surgery. In FastAPI, an endpoint can simply say "I need a database connection" or "I need the logged-in user", and FastAPI hands it over. This is called **dependency injection**.

2. A checkpoint around everything

An office building has a reception desk. Everyone passes it on the way in and out: it records the time, checks badges and gives directions. **Middleware** is the reception desk of an API. Every request passes through it.

3. Who are you, and what may you do?

Question	Name	Office example	Error if it fails
Who are you?	Authentication	Showing your ID at reception	401
What may you do?	Authorisation	Your badge opens some doors, not all	403

4. Never keep passwords in a drawer

A responsible company never stores your actual password. It stores a scrambled fingerprint of it, called a **hash**. When you log in, it scrambles what you typed the same way and compares fingerprints. If the database is ever stolen, the real passwords are not in it.

5. A visitor pass that cannot be faked

After you log in, the server gives you a **token**, like a visitor pass with your name, role and expiry time, stamped with a special seal. You show it with every request. Anyone can read the pass, but nobody can change it without breaking the seal. This kind of pass is called a **JWT** (JSON Web Token).

Key idea: the server checks the seal, not a list of logged-in people. That makes it fast and easy to scale.

6. Think about these before class

- Why do websites ask you to log in again after some time?
- What should happen if someone copies your visitor pass?
- Think of an app where different users can see different things. Who decides what each person can see?

Anzen daiichi (安全第一): safety first